

Windows Server Concepts, Network Administration, SMB, RDP, and Enterprise Enumeration

These notes were written by Kevin Beideman. The recommended time to understand and practice these concepts is 3 hours and 5 minutes.

SMB + Windows File Sharing Deep Dive

SMB = File sharing (Ports: 445/139), Administrative Shares, Lateral Movement

Run: **net share**. It manages the shared resources on a network. Next, **Get-SmbShare**. This displays the SMB shared folders currently configured on a system.

SMB shares are folders, printers, or resources on a Windows system that are made accessible over a network using SMB protocol. Administrative shares are special hidden SMB shares that Windows automatically creates for system administration and remote management.

1. C\$: remote access to C: drive
2. ADMIN\$: access to the Windows folder
3. IPC\$: inter-process communication

An enterprise is a large organization or company that operates many computers, users, departments, servers, and networked systems together. (Ex: banks, hospitals, universities, etc.) SMB is everywhere in enterprise environments: shared drives, file servers, printer sharing, backups, software develop, and admin management.

Run: **netstat -ano | findstr LISTENING**

SMB over NetBIOS and Direct SMB: NetBIOS stands for: Network Basic I/O System. Older Windows systems originally used SMB through NetBIOS. Port: TCP 139
Modern Windows systems use: Direct SMB over TCP/IP. It uses port TCP 445.

Security: SMB signing is a security feature that helps protect SMB communication from being modified or tampered with while data travels across the network. It adds a cryptographic signature to SMB packets so systems can verify: the data came from the expected sender and was not altered in transit.

SMBv1 is the original and oldest version of the SMB protocol.

Run: **Get-Childitem C:**

A temp directory is a folder used by the OS and programs to store temporary files while tasks are running. The files are usually not meant to stay permanently. Attackers love temp directories because they are commonly writable, frequently ignored, expected to contain random files, and used by many legitimate programs.

RDP + Remote Administration

RDP: Allows a user to remotely control another computer over a network as if they were physically sitting in front of it. It works by transmitting the remote computer's desktop display to your device while sending your keyboard and mouse input back to the remote system.

1. Client Starts Connection. **Remote Desktop Client.**
2. TCP Connection Established. Computer connects to remote system using TCP 3389, the default RDP port.
3. Authentication: Remote computer verifies: username, password
4. Remote Session starts

Run: **Get-Service TermService**. This retrieves info about the service named TermService which is the Remote Desktop Services service.

To check RDP Ports: **netstat -ano | findstr 3389**

Brute Forcing is a method attackers use to repeatedly guess passwords, login credentials, encryption keys, or codes until they eventually find the correct one. Automated trial and error. Another attack is Credential Stuffing where attackers use stolen username/password combinations from previous data breaches to try logging into other accounts. It works because many people reuse the same passwords across multiple websites and services.

Open **wf.msc**. Network segmentation is the practice of dividing a network into smaller isolated sections to improve: security, performance, access control, and containment.

Windows Administration + Privileges

Run: **net user**. Then, **net localgroup**. This will list the local groups, which are collections of users that share permissions and privileges on a specific machine. After, run **net localgroup administrators**.

Privilege escalation is when a user or attacker gains higher permissions or access rights than they originally had on a system or network. Least privilege is a cybersecurity principle where users, programs, and systems are only given the minimum permissions necessary to perform their tasks, nothing more.

User Account Control (UAC): A Windows security feature that helps prevent unauthorized or dangerous changes to the OS by requiring approval before actions with elevated privileges are performed. It is the popup that says: Do you want to allow this app to make changes to your device?

Run: **whoami /priv**. This shows the privileges to the current user's security access token in Windows.

Run: **schtasks**
